Database Governance (Security at the DBMS storage level)

Cryptography

Cryptography

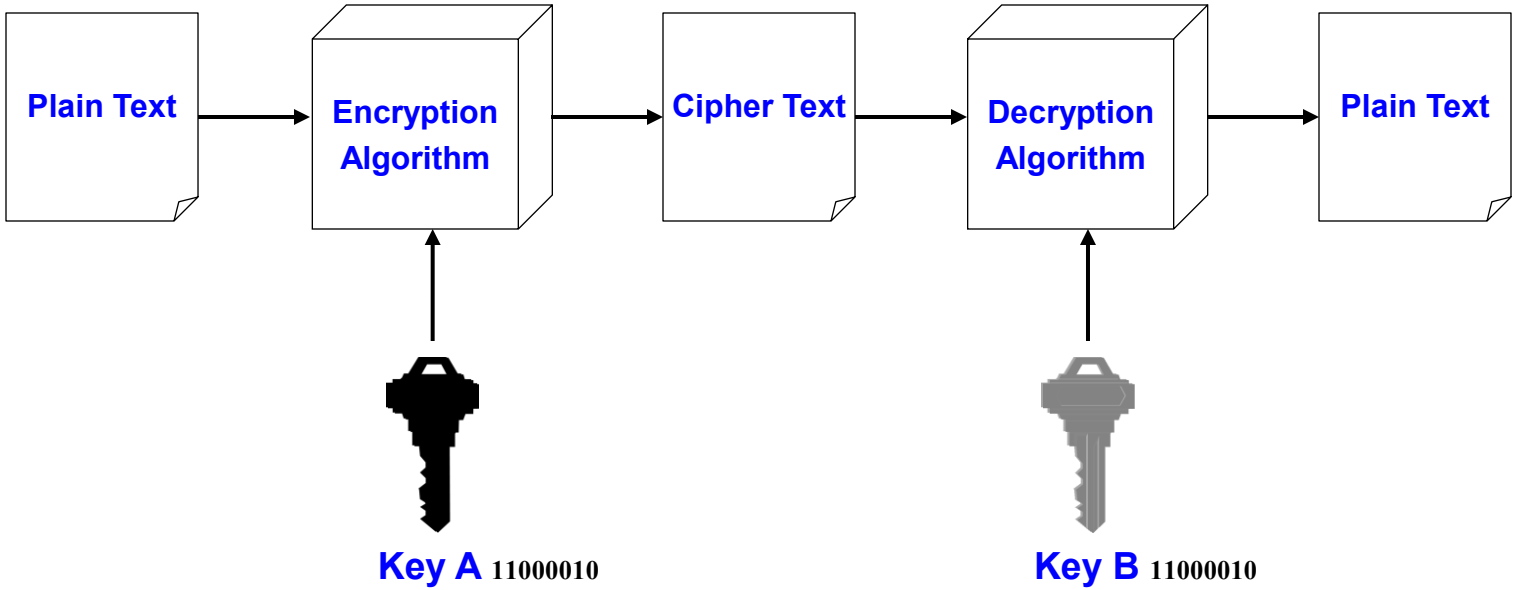
Basics

- Cryptography is the science of secret, or hidden writing
- It has two main Components:
  1. Encryption
     - Practice of hiding messages so that they can not be read by anyone other than the intended recipient
  2. Authentication & Integrity
     - Ensuring that users of data/resources are the persons they claim to be and that a message has not been altered

Encryption

Cipher

- Cipher is a method for encrypting messages



- Encryption algorithms are standardized & published
- The key which is an input to the algorithm is secret
  - Key is a string of numbers or characters
  - If same key is used for encryption & decryption the algorithm is called symmetric
  - If different keys are used for encryption & decryption the algorithm is called asymmetric

Encryption

Symmetric Algorithms

- Algorithms in which the key for encryption and decryption are the same are Symmetric
  - Example: Caesar Cipher
- Types:
  1. Block Ciphers
     - Encrypt data one block at a time (typically 64 bits, or 128 bits)
     - Used for a single message
  2. Stream Ciphers
     - Encrypt data one bit or one byte at a time
     - Used if data is a constant stream of information

Symmetric Encryption

Key Strength

- Strength of algorithm is determined by the size of the key
  - The longer the key the more difficult it is to crack
- Key length is expressed in bits
  - Typical key sizes vary between 48 bits and 448 bits
- Set of possible keys for a cipher is called key space
  - For 40-bit key there are 2^{40} possible keys
  - For 128-bit key there are 2^{128} possible keys
  - Each additional bit added to the key length doubles the security
- To crack the key the hacker has to use brute-force

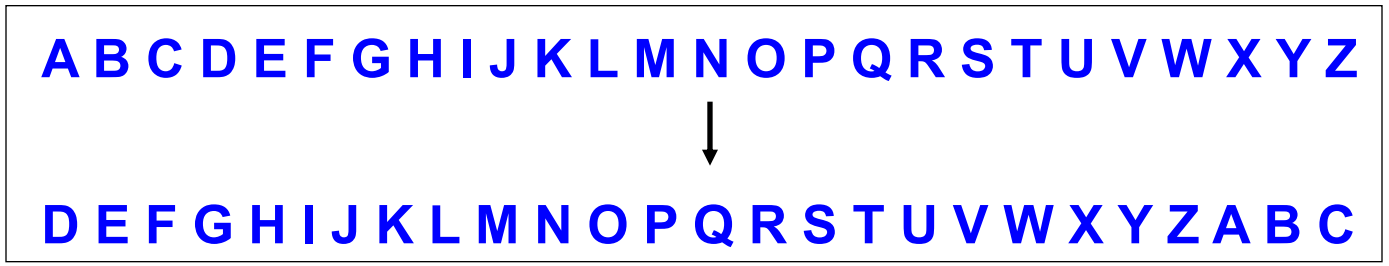
  (i.e. try all the possible keys till a key that works is found)
  - Super Computer can crack a 56-bit key in 24 hours
  - It will take 2^{72} times longer to crack a 128-bit key

  (Longer than the age of the universe)

Substitution Ciphers

Caesar Cipher

- Caesar Cipher is a method in which each letter in the alphabet is rotated by three letters as shown



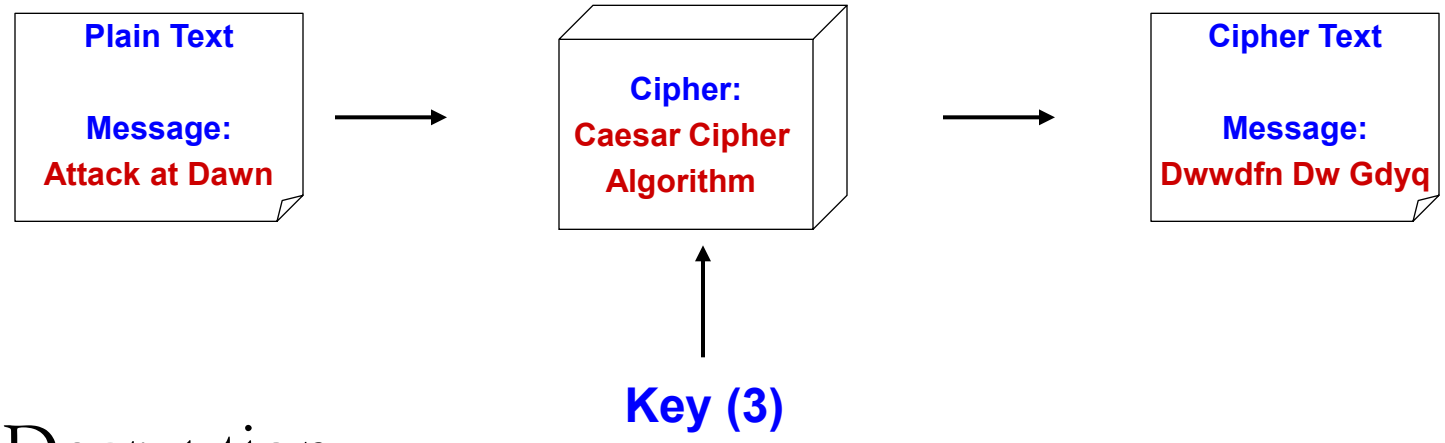
- Let us try to encrypt the message
  - Attack at Dawn

Dwwdfn Dw Gdyq

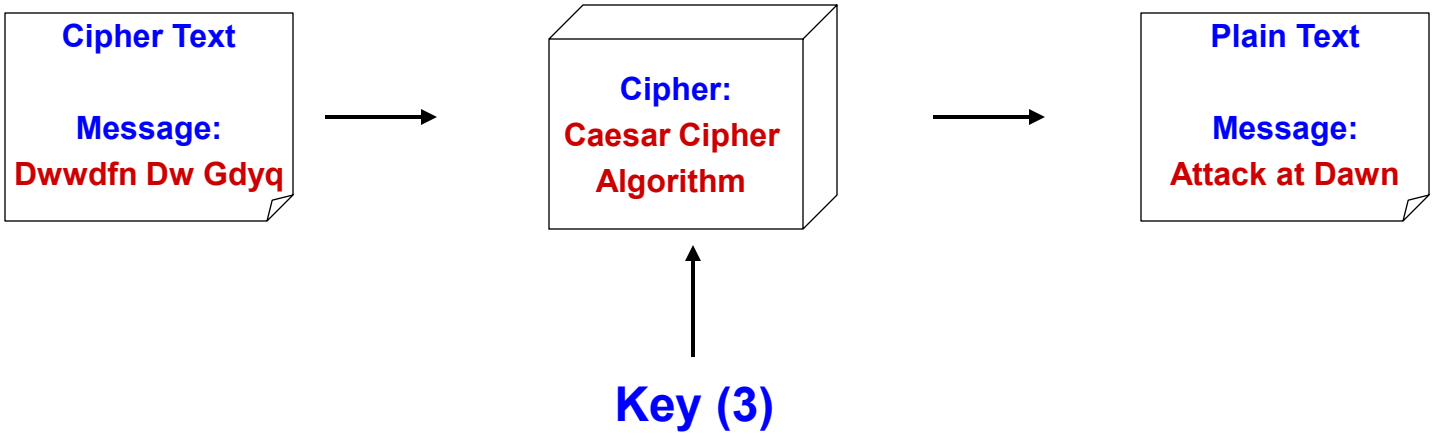
Substitution Ciphers

Caesar Cipher

Encryption



Decryption



Substitution Cipher

Monoalphabetic Cipher

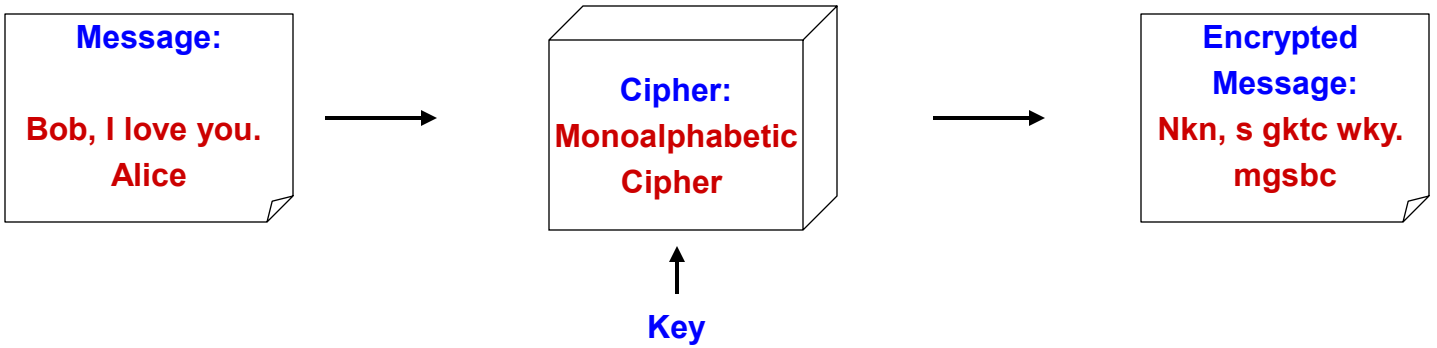
- Any letter can be substituted for any other letter
  - Each letter has to have a unique substitute

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

↓

M N B V C X Z A S D F G H J K L P O I U Y T R E W Q

- There are 26! pairing of letters ($\sim 10^{26}$)
- Brute Force approach would be too time consuming
  - Statistical Analysis would make it feasible to crack the key



Substitution Cipher

Monoalphabetic Cipher

- Rather than just shifting the alphabet
- Could shuffle (jumble) the letters arbitrarily
- Each plaintext letter maps to a different random cipher text letter
- hence key is 26 letters long

```
Plain:   abcdefghijklmnopqrstuvwxyz
Cipher: DKVQFIBJWPESCXHTMYAUOLRGZN
Plaintext:   ifwewishtoreplaceletters
Cipher text: WIRFRWAJUHYFTSDVFSFUUFYA
```

polyalphabetic substitution cipher

- The Vigenère cipher is an example of a polyalphabetic substitution cipher. A polyalphabetic substitution cipher is similar to a monoalphabetic substitution except that the cipher alphabet is changed periodically while enciphering the message. This makes the cipher less vulnerable to cryptanalysis using letter frequencies.

Keyword Method

- **The keyword can be of any length greater than one, which provides an unlimited number of possible keys. To form the key, the sender writes the keyword repeatedly on the line underneath the plaintext. The plaintext-key pairs in each column will then be enciphered using the Vigenère square**

Example:
Message: "What fools these mortals be"

Keyword: Puck

plaintext:	W	H	A	T	F		O	O	L	S	T		H	E	S	E	M		O	R	T	A	L		S	B	E
key:	P	U	C	K	P		U	C	K	P	U		C	K	P	U	C		K	P	U	C	K		P	U	C
ciphertext:	L	B	C	D	U		I	Q	V	H	N		J	O	H	Y	O		Y	G	N	C	V		H	V	G

polyalphabetic substitution cipher

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

Example:

Message: "What fools these mortals be"

Keyword: Puck

plaintext:	W	H	A	T	F		O	O	L	S	T		H	E	S	E	M		O	R	T	A	L		S	B	E
key:	P	U	C	K	P		U	C	K	P	U		C	K	P	U	C		K	P	U	C	K		P	U	C
ciphertext:	L	B	C	D	U		I	Q	V	H	N		J	O	H	Y	O		Y	G	N	C	V		H	V	G

Ciphers

Shannon's Characteristics of "Good" Ciphers

- The amount of secrecy needed should determine the amount of labor appropriate for the encryption and decryption.
- The set of keys and the enciphering algorithm should be free from complexity.
- The implementation of the process should be as simple as possible.
- Errors in ciphering should not propagate and cause corruption of further information in the message.
- The size of the enciphered text should be no larger than the text of the original message.

Encryption Systems

Properties of Trustworthy Systems

- It is based on sound mathematics.
  - Good cryptographic algorithms are are derived from solid principles.
- It has been analyzed by competent experts and found to be sound.
  - Since it is hard for the writer to envisage all possible attacks on the algorithm
- It has stood the "test of time."
  - Over time people continue to review both mathematical foundations of an algorithm and the way it builds upon those foundations.
  - The flaws in most algorithms are discovered soon after their release.

Cryptanalysis

Techniques

- Cryptanalysis is the process of breaking an encryption code
  - Tedious and difficult process
- Several techniques can be used to deduce the algorithm
  - Attempt to recognize patterns in encrypted messages, to be able to break subsequent ones by applying a straightforward decryption algorithm
  - Attempt to infer some meaning without even breaking the encryption, such as noticing an unusual frequency of communication or determining something by whether the communication was short or long
  - Attempt to deduce the key, in order to break subsequent messages easily
  - Attempt to find weaknesses in the implementation or environment of use of encryption
  - Attempt to find general weaknesses in an encryption algorithm, without necessarily having intercepted any messages

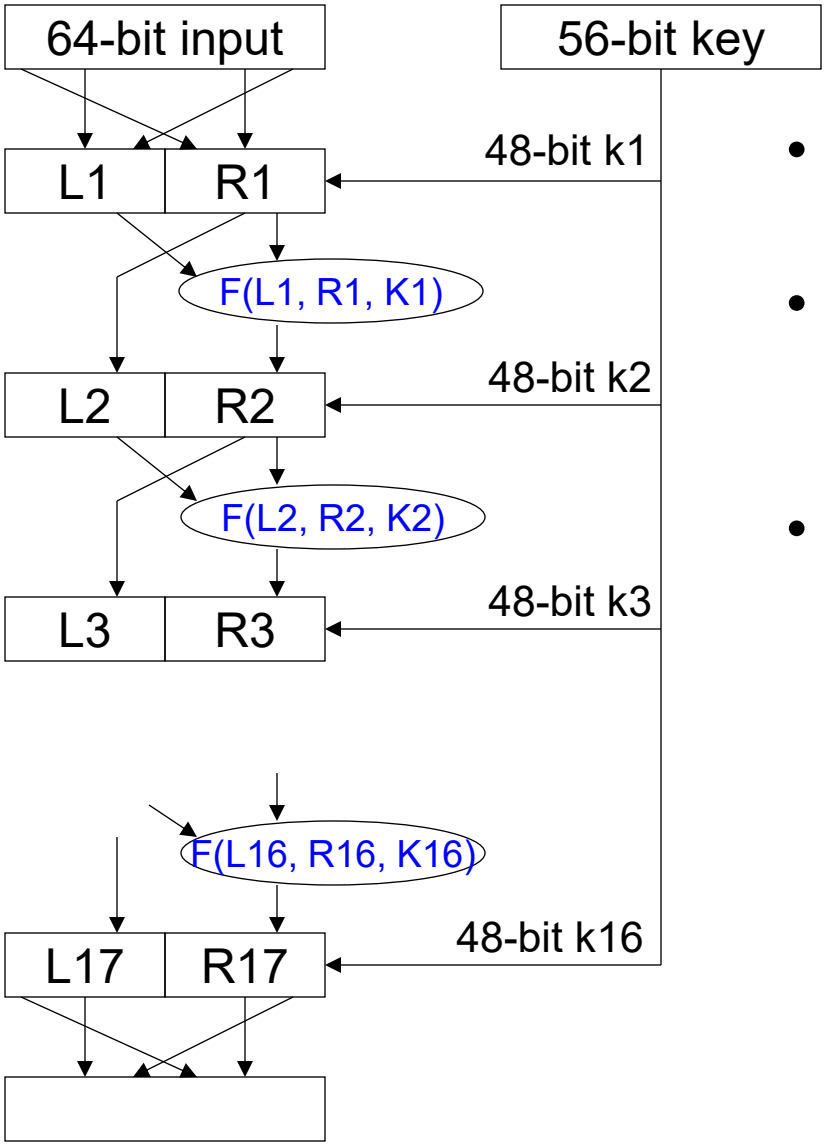
Data Encryption Standard (DES)

Basics

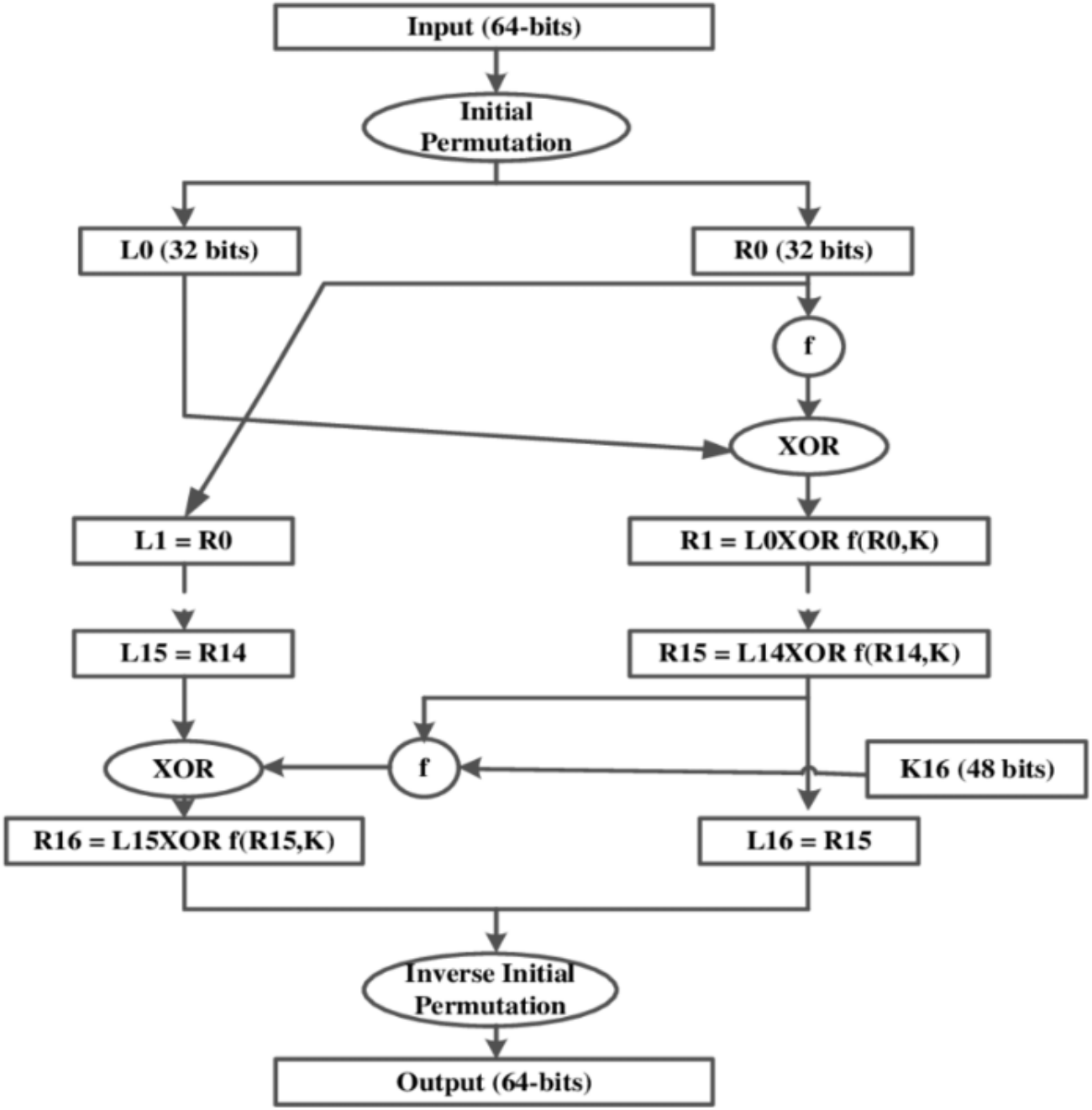
- Goal of DES is to completely scramble the data and key so that every bit of cipher text depends on every bit of data and ever bit of key
- DES is a block Cipher Algorithm
  - Encodes plaintext in 64 bit chunks
  - One parity bit for each of the 8 bytes thus it reduces to 56 bits
- It is the most used algorithm
  - Standard approved by US National Bureau of Standards for Commercial and nonclassified US government use in 1993

Data Encryption Standard (DES)

Basics

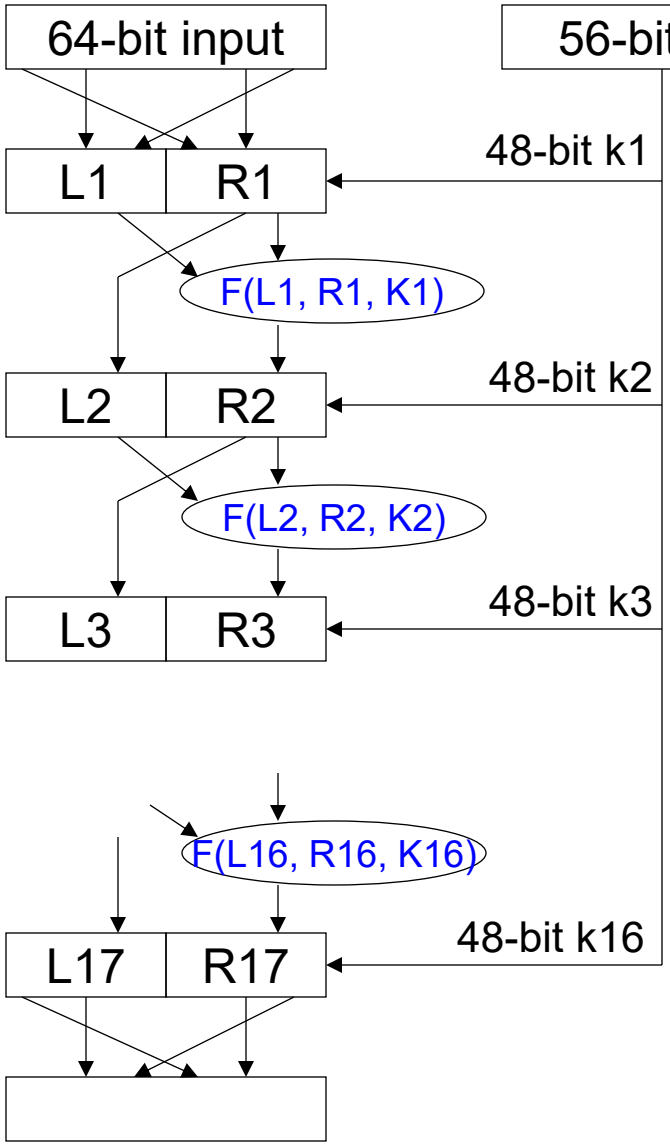


- DES run in reverse to decrypt
- Cracking DES
  - 1997: 140 days
  - 1999: 14 hours
- TripleDES uses DES 3 times in tandem
  - Output from 1 DES is input to next DES


Input (64-bits)
Initial Permutation
L0 (32 bits)
R0 (32 bits)
f
XOR
L1 = R0
R1 = L0XOR f(R0,K)
L15 = R14
R15 = L14XOR f(R14,K)
XOR
f
K16 (48 bits)
R16 = L15XOR f(R15,K)
L16 = R15
Inverse Initial Permutation
Output (64-bits)

Data Encryption Standard (DES)

Basics



- **Operation of each round is identical – taking output of the pervious round as input**
- **During each round – the rightmost 32 bits of input are moved to left 32 bits of the output**
- ***The function F involves expansion of 4-bit chunks into 6-bit chunks , exclusive or-ing with the expanded 6-bit chunks of the 48-bit key Ki, a substitution operation and further exclusive OR-ing with the leftmost 32 bits of the input.***
- **The resulting 32 bits of the input of the function is then used as the rightmost 32 bits of the round's 64-bit output**

Key Structure

Initial Key Size: The original key for DES is 64 bits, but only 56 bits are used for encryption.

Key Parity Bits: The remaining 8 bits are parity bits, added for error detection. Each of these parity bits is set to ensure that the corresponding 7 bits have an odd number of 1s.

Key Scheduling in DES

1. **Key Transformation:** The 56-bit key undergoes a key scheduling process to produce subkeys for each round of encryption.
2. **Subkey Generation:**
    1. DES has 16 rounds of encryption.
    2. For each round, a 48-bit subkey is derived from the original 56-bit key.
    3. A 48-bit subkey is selected from the 56-bit key using a specific permutation.

Why 48 Bits?

- The use of a 48-bit subkey allows the algorithm to perform bitwise operations (such as XOR) effectively, ensuring that each round of encryption has enough complexity and diffusion.
- **Security:** The reduction to 48 bits helps balance security with efficiency. While 56 bits are already considered small by modern standards, the 48-bit subkeys increase the number of possible combinations in each round without significantly complicating the encryption process.

Encryption Algorithm

(Time to explore more by yourself)

Algorithm	Type	Key Size	Features
DES	Block Cipher	56 bits	Most Common, Not strong enough
TripleDES	Block Cipher	168 bits (112 effective)	Modification of DES, Adequate Security
Blowfish	Block Cipher	Variable (Up to 448 bits)	Excellent Security
AES	Block Cipher	Variable (128, 192, or 256 bits)	Replacement for DES, Excellent Security
RC4	Stream Cipher	Variable (40 or 128 bits)	Fast Stream Cipher, Used in most SSL implementations

Symmetric Encryption

Limitations

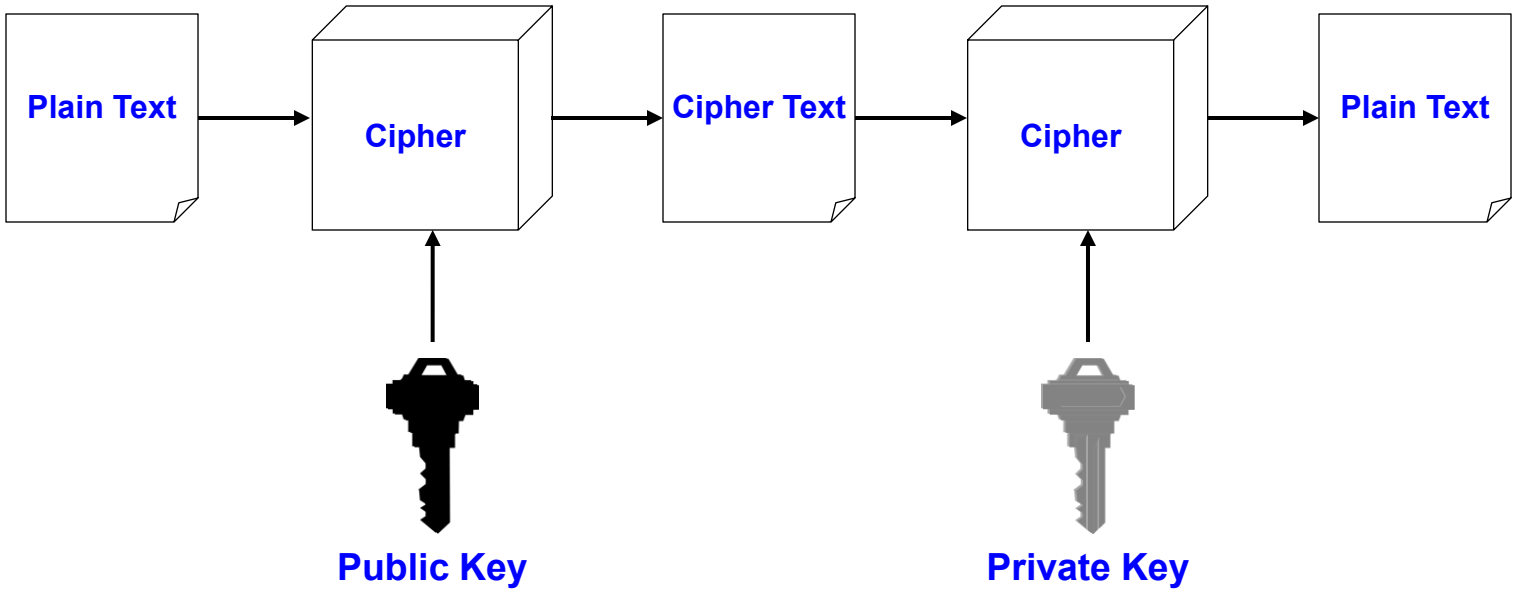
- Any exposure to the secret key compromises secrecy of ciphertext
- A key needs to be delivered to the recipient of the coded message for it to be deciphered
  - Potential for eavesdropping attack during transmission of key



Asymmetric Encryption

Basics

- Uses a pair of keys for encryption
  - Public key for encryption
  - Private key for decryption
- Messages encoded using public key can only be decoded by the private key
  - Secret transmission of key for decryption is not required
  - Every entity can generate a key pair and release its public key



Asymmetric Encryption

Types

- Two most popular algorithms are RSA & El Gamal
  - RSA (Rivest–Shamir–Adleman)
    - Developed by Ron Rivest, Adi Shamir, Len Adelman
    - Both public and private key are interchangable
    - Variable Key Size (512, 1024, or 2048 bits)
    - Most popular public key algorithm
  - El Gamal
    - Developed by Taher ElGamal
    - Variable key size (512 or 1024 bits)
    - Less common than RSA

Asymmetric Encryption

RSA

- Choose two large prime numbers p & q
- Compute n=pq and z=(p-1)(q-1)
- Choose number e, less than n, which has no common factor (other than 1) with z
- Find number d, such that ed – 1 is exactly divisible by z
- Keys are generated using n, d, e
  - Public key is (n,e)
  - Private key is (n, d)
- Encryption: $c = m^e \bmod n$
  - m is plain text
  - c is cipher text
- Decryption: $m = c^d \bmod n$
- Public key is shared and the private key is hidden

Asymmetric Encryption

RSA

- P=5 & q=7
- n=5*7=35 and z=(4)*(6) = 24
- e = 5
- d = 29 , (29x5 –1=144) (144/24=6) is exactly divisible by 24
- Keys generated are
  - Public key: (35,5), n=35
  - Private key is (35, 29)
- Encrypt the word love using ($c = m^e \bmod n$)
  - Assume that the alphabets are between 1 & 26

Plain Text	Numeric Representation	m^e	Cipher Text ($c = m^e \bmod n$)
l	12	248832	17
o	15	759375	15
v	22	5153632	22
e	5	3125	10

Asymmetric Encryption

RSA

- Decrypt the word love using ($m = c^d \bmod n$)
  - $n = 35$, c = cipher text, $d = 29$

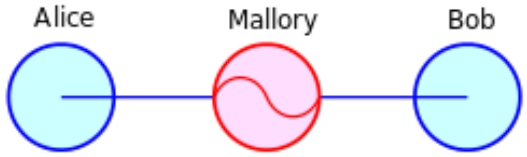
Cipher Text	c^d	($m = c^d \bmod n$)	Plain Text
17	481968572106750915091411825223072000	12	l
15	127834039488589391112327575683594 00	15	o
22	852643319086537701956194499721110000000	22	v
10	100000000000000000000000000000	5	e

Asymmetric Encryption

Weaknesses

- Efficiency is lower than Symmetric Algorithms
  - A 1024-bit asymmetric key is equivalent to 128-bit symmetric key
- Potential for man-in-the middle attack
- It is problematic to get the key pair generated for the encryption

- man-in-the middle attack: cyberattack where the attacker secretly relays and possibly alters the communications between two parties who believe that they are directly communicating with each other



Asymmetric Encryption

Weaknesses

1. Alice sends a message to Bob, which is intercepted by Mallory:

   Alice *"Hi Bob, it's Alice. Give me your key."* → Mallory Bob

2. Mallory relays this message to Bob; Bob cannot tell it is not really from Alice:

   Alice Mallory *"Hi Bob, it's Alice. Give me your key."* → Bob

3. Bob responds with his encryption key:

   Alice Mallory ← *[Bob's key]* Bob

4. Mallory replaces Bob's key with her own, and relays this to Alice, claiming that it is Bob's key:

   Alice ← *[Mallory's key]* Mallory Bob

5. Alice encrypts a message with what she believes to be Bob's key, thinking that only Bob can read it:

   Alice *"Meet me at the bus stop!" [encrypted with Mallory's key]* → Mallory Bob

6. However, because it was actually encrypted with Mallory's key, Mallory can decrypt it, read it, modify it (if desired), re-encrypt with Bob's key, and forward it to Bob:

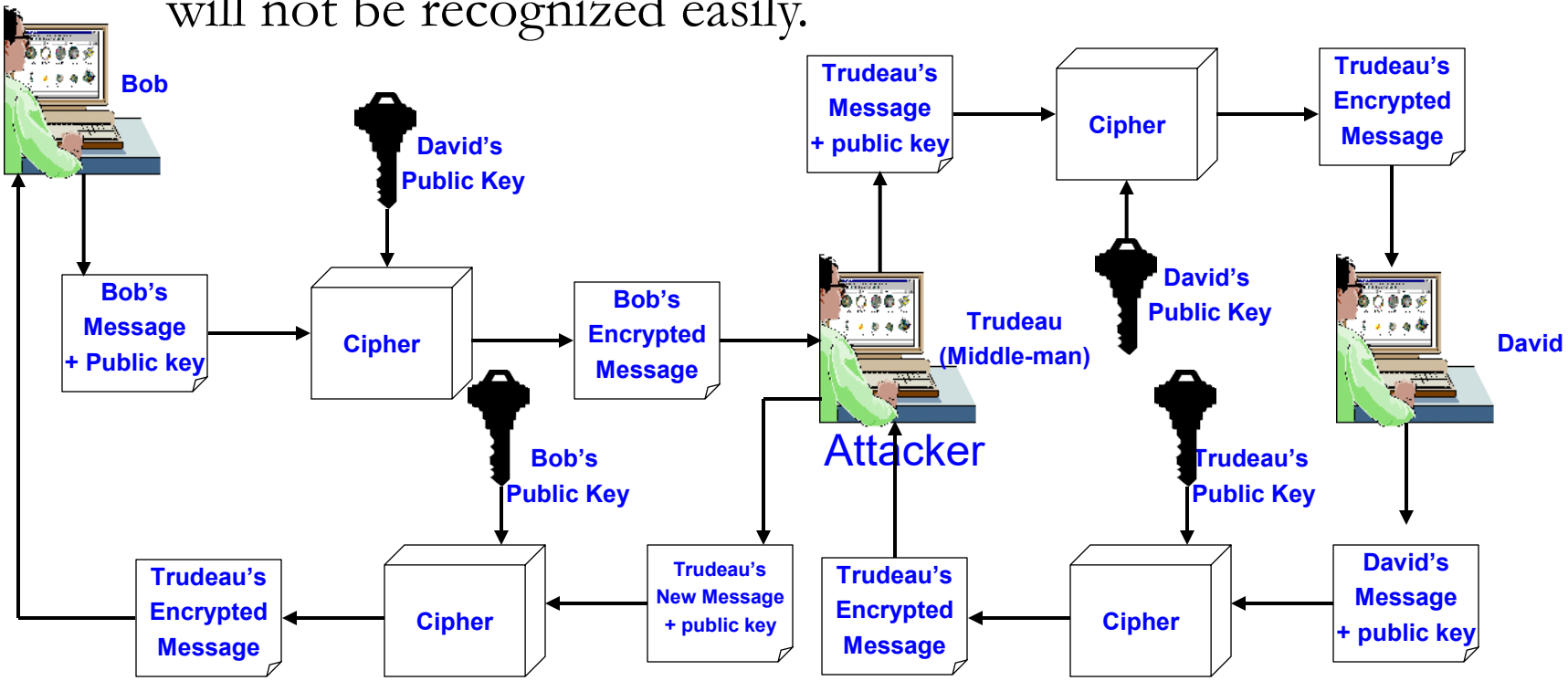
   Alice Mallory *"Meet me at the van down by the river!" [encrypted with Bob's key]* → Bob

7. Bob thinks that this message is a secure communication from Alice.

Asymmetric Encryption

Man-in-the-middle Attack

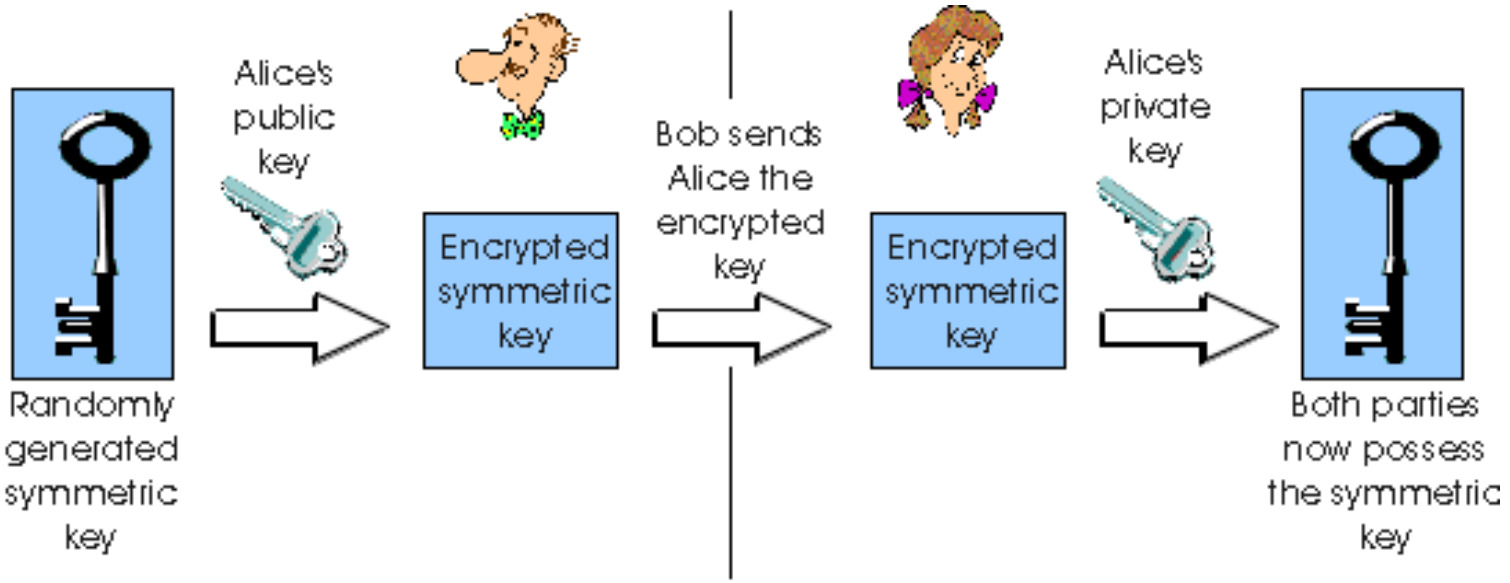
- Hacker could generate a key pair, give the public key away and tell everybody, that it belongs to somebody else. Now, everyone believing it will use this key for encryption, resulting in the hacker being able to read the messages. If he encrypts the messages again with the public key of the real recipient, he will not be recognized easily.



Asymmetric Encryption

Session-Key Encryption

- Used to improve efficiency
  - Symmetric key is used for encrypting data
  - Asymmetric key is used for encrypting the symmetric key
  - Many Internet commerce paradigms make use of session keys.



Asymmetric Encryption

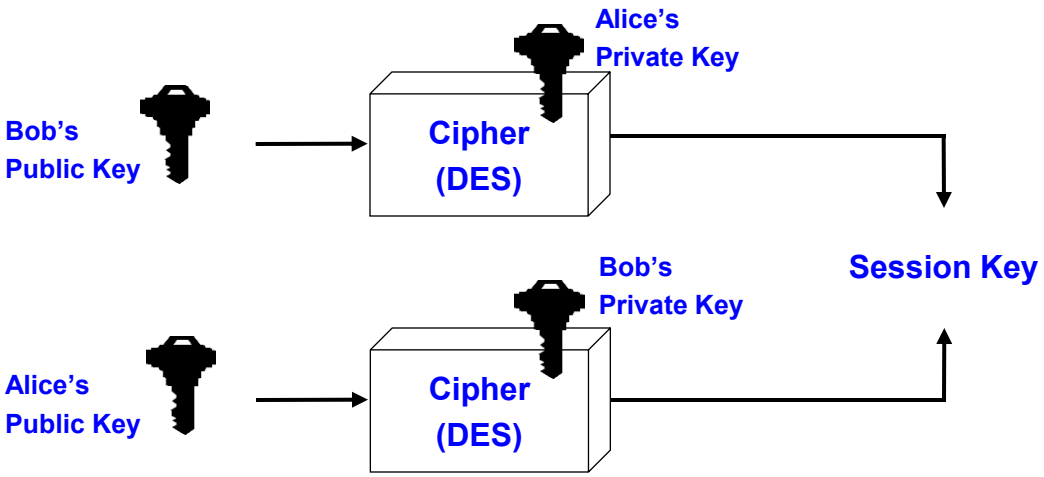
Encryption Protocols

- Pretty Good Privacy (PGP)
  - Used to encrypt e-mail using session key encryption
  - Combines RSA, TripleDES, and other algorithms
- Secure/Multipurpose Internet Mail Extension (S/MIME)
  - Newer algorithm for securing e-mail
  - Backed by Microsoft, RSA, AOL
- Secure Socket Layer(SSL) and Transport Layer Socket(TLS)
  - Used for securing TCP/IP Traffic
  - Mainly designed for web use
  - Can be used for any kind of internet traffic

Asymmetric Encryption

Key Agreement

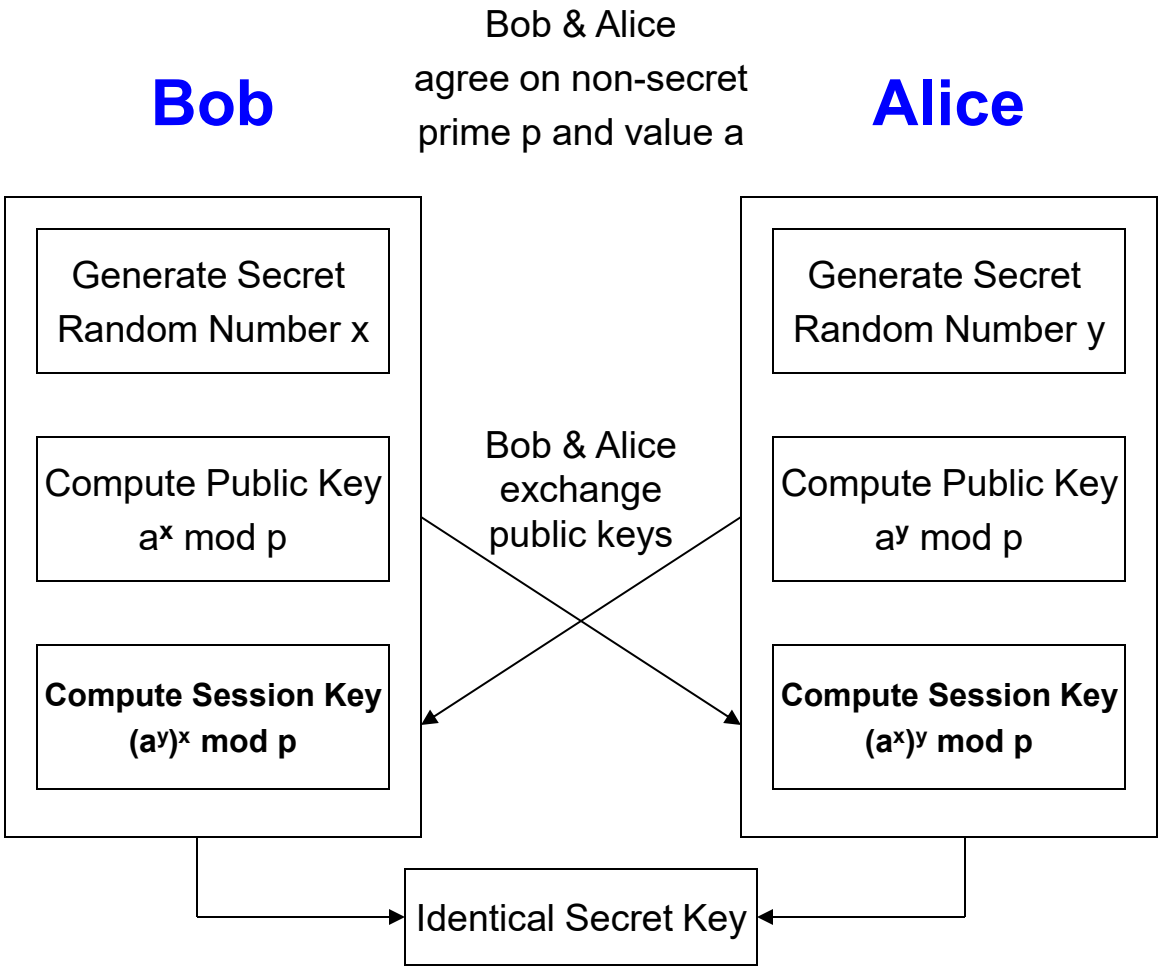
- Key agreement is a method to create secret key by exchanging only public keys.
- Example
  - Bob sends Alice his public key
  - Alice sends Bob her public key
  - Bob uses Alice's public key and his private key to generate a session key
  - Alice uses Bob's public key and her private key to generate a session key
  - Using a key agreement algorithm both will generate same key
  - Bob and Alice do not need to transfer any key



Alice and Bob Generate Same Session Key!

Asymmetric Encryption

Key Diffie-Hellman Mathematical Analysis



Asymmetric Encryption

Key Agreement con't.

- Diffie-Hellman is the first key agreement algorithm
  - Invented by Whitfield Diffie & Martin Hellman
  - Provided ability for messages to be exchanged securely without having to have shared some secret information previously
- No exchange of secret keys
  - Man-in-the middle attack avoided

Authentication

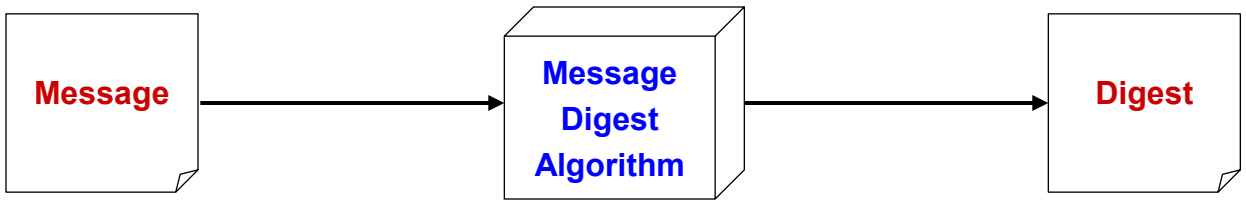
Basics

- Authentication is the process of validating the identity of a user or the integrity of a piece of data.
- There are three technologies that provide authentication
  - Message Digests / Message Authentication Codes
  - Digital Signatures
  - Public Key Infrastructure
- There are two types of user authentication:
  - Identity presented by a remote or application participating in a session
  - Sender's identity is presented along with a message.

Authentication

Message Digests

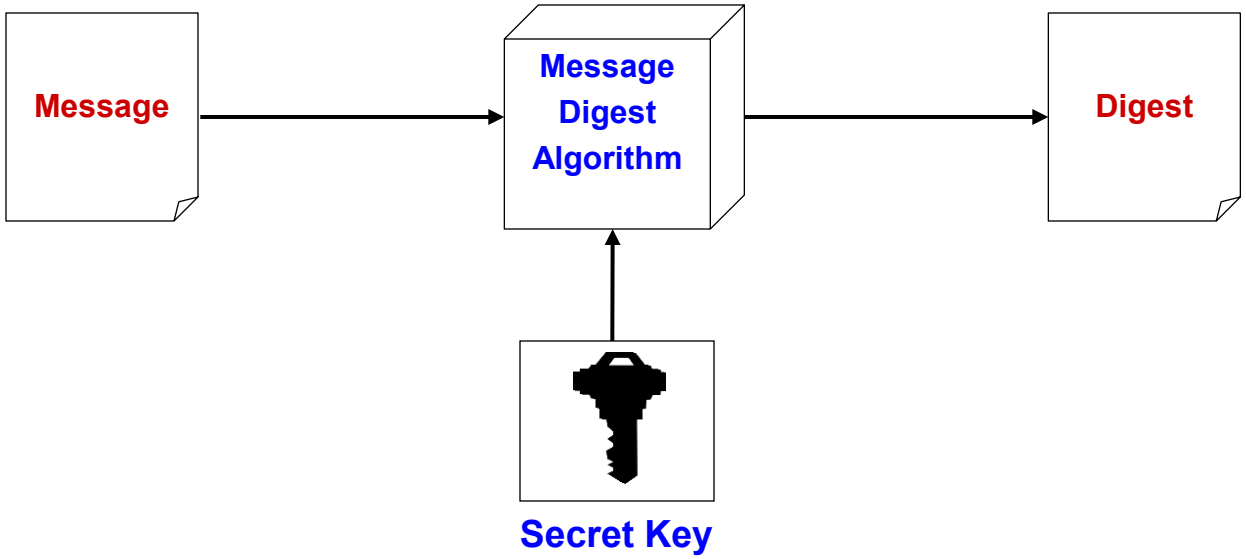
- A message digest is a fingerprint for a document
- Purpose of the message digest is to provide proof that data has not altered
- Process of generating a message digest from data is called hashing
- Hash functions are one way functions with following properties
  - Infeasible to reverse the function
  - Infeasible to construct two messages which hash the same digest
- Commonly used hash algorithms are
  - MD5 – 128 bit hashing algorithm
  - SHA & SHA-1 – 162 bit hashing algorithm



Message Authentication Codes

Basics

- A message digest created with a key
- Creates security by requiring a secret key to be possessed by both parties in order to retrieve the message



Password Authentication

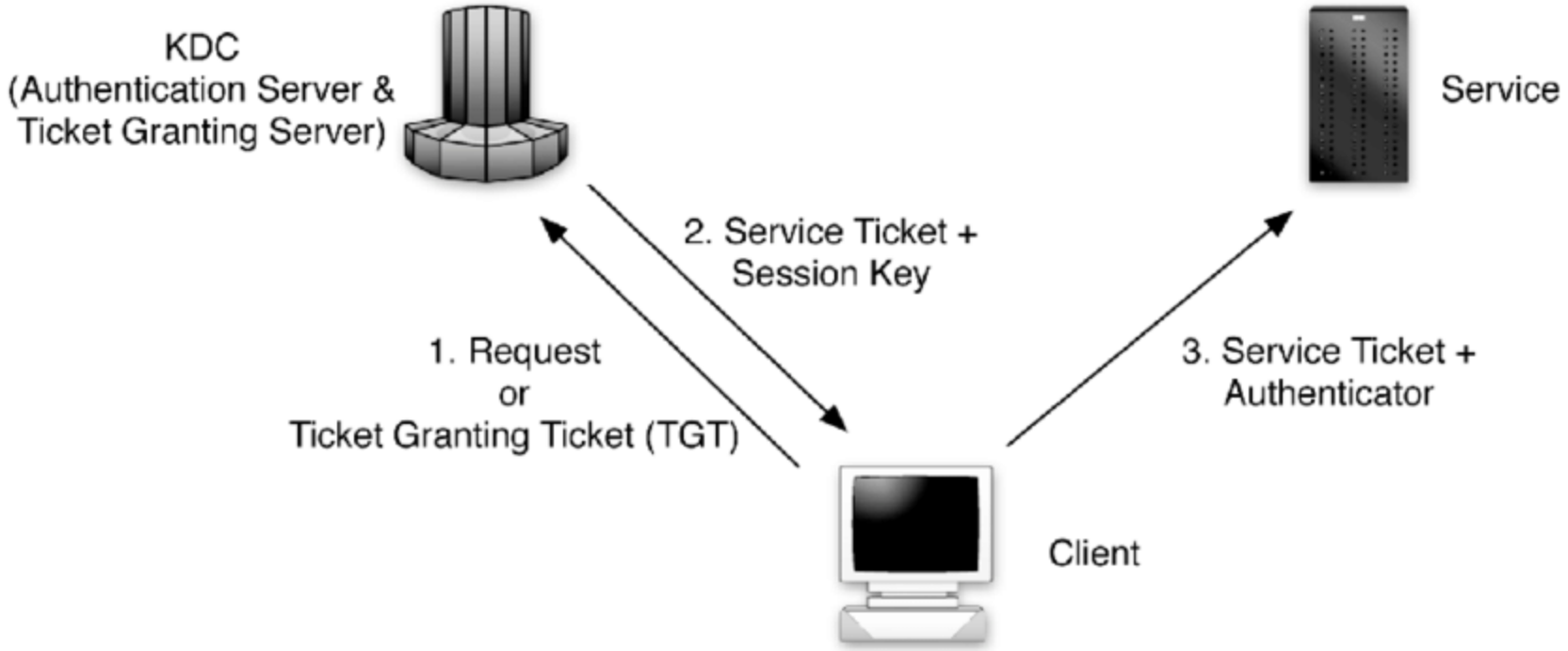
Basics

- Password is secret character string only known to user and server
- Message Digests commonly used for password authentication
- Stored hash of the password is a lesser risk
  - Hacker can not reverse the hash except by brute force attack
- Problems with password based authentication
  - Attacker learns password by social engineering
  - Attacker cracks password by brute-force and/or guesswork
  - Eavesdrops password if it is communicated unprotected over the network
  - Replays an encrypted password back to the authentication server

Authentication Protocols

Kerberos

- Kerberos is an authentication service that uses symmetric key encryption and a key distribution center.
- Kerberos Authentication server contains symmetric keys of all users and also contains information on which user has access privilege to which services on the network



Authentication

Personal Tokens

- Personal Tokens are hardware devices that generate unique strings that are usually used in conjunction with passwords for authentication
- A variety of different physical forms of tokens exist
  - e.g. hand-held devices, Smart Cards, PCMCIA cards, USB tokens



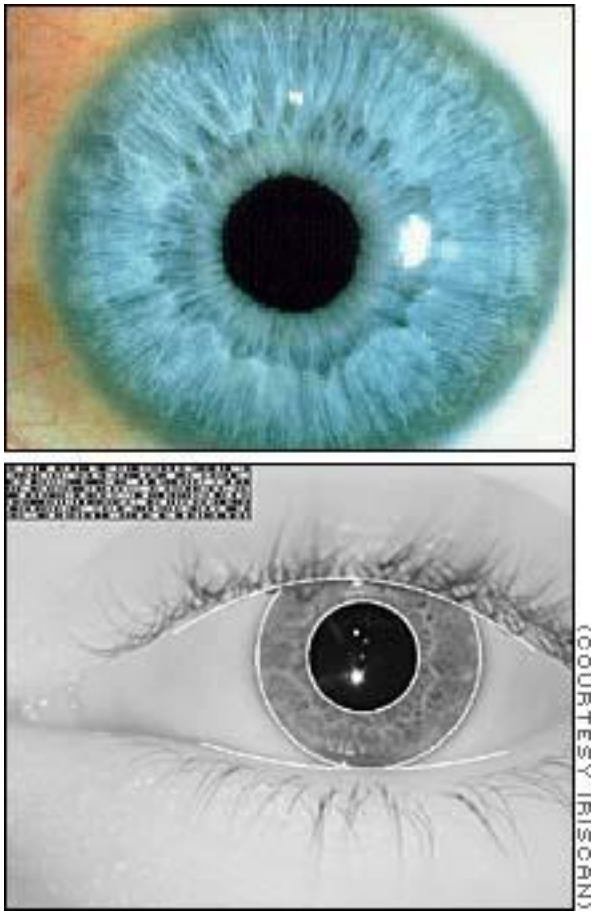
Authentication

Biometrics

- Uses certain biological characteristics for authentication
  - Biometric reader measures physiological indicia and compares them to specified values
  - It is not capable of securing information over the network
- Different techniques exist
  - Fingerprint Recognition
  - Voice Recognition
  - Handwriting Recognition
  - Face Recognition
  - Retinal Scan
  - Hand Geometry Recognition

Authentication

Iris Recognition



The scanning process takes advantage of the natural patterns in people's irises, digitizing them for identification purposes

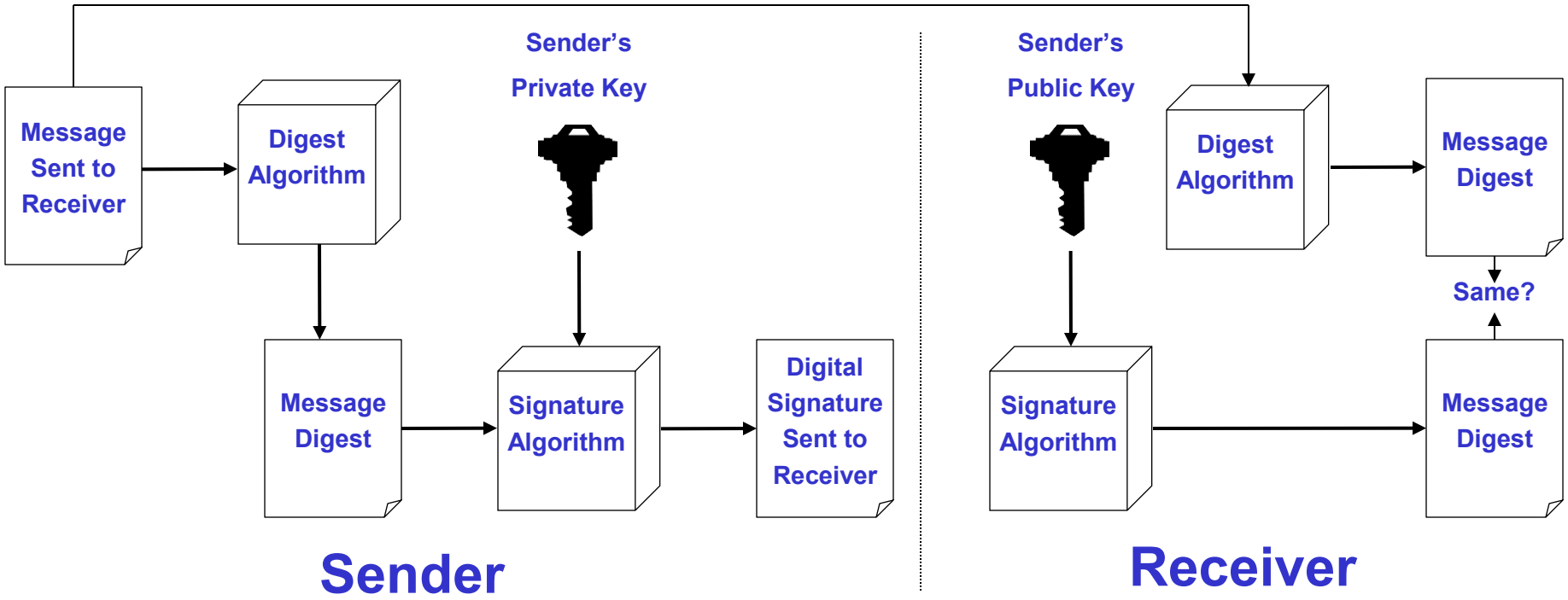
Facts

- Probability of two irises producing exactly the same code: 1 in 10 to the 78th power
- Independent variables (degrees of freedom) extracted: 266
- IrisCode record size: 512 bytes
- Operating systems compatibility: DOS and Windows (NT/95)
- Average identification speed (database of 100,000 IrisCode records): one to two seconds

Authentication

Digital Signatures

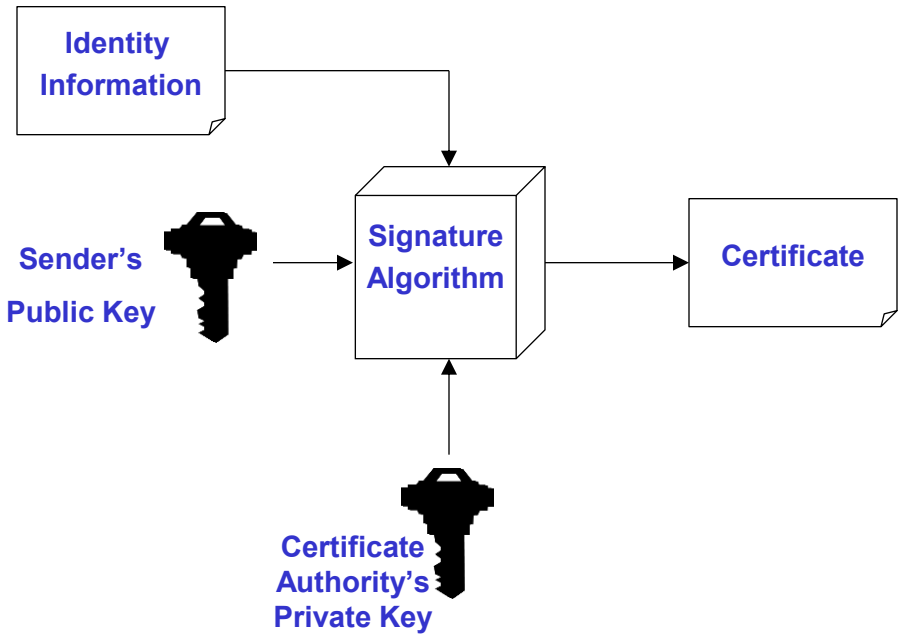
- A digital signature is a data item which accompanies or is logically associated with a digitally encoded message.
- It has two goals
  - A guarantee of the source of the data
  - Proof that the data has not been tampered with



Authentication

Digital Certificates

- A digital certificate is a signed statement by a trusted party that another party's public key belongs to them.
- Verisign is industry standard certificate authority



Cryptanalysis

Basics

- Practice of analyzing and breaking cryptography
- Resistance to crypt analysis is directly proportional to the key size
  - With each extra byte strength of key doubles
- Variety of methods for safe guarding keys (Key Management)
  - Encryption & computer access protection
  - Smart Cards